

AI SECURITY COPILOT - SECURITY ASSESSMENT REPORT

Target: https://demo.example.com

Assessment Type: Web Application Security Assessment

Assessment Date: August 22, 2026

FINDING 001: SQL Injection

Severity: Critical

Affected Endpoint: /api/users

Description: The application appears to directly include user-supplied input in a database query without sufficient parameterization or input validation. An attacker may be able to manipulate the SQL query and access or modify unauthorized database information.

Evidence: The parameter "user_id" accepts SQL metacharacters and produces database-related error responses.

Recommendation: Use parameterized queries or prepared statements. Validate and sanitize user input and avoid dynamically constructing SQL queries from untrusted data.

FINDING 002: Cross-Site Scripting (XSS)

Severity: High

Affected Endpoint: /search

Description: User-controlled search input is reflected in the application's response without adequate output encoding. This could allow an attacker to execute malicious JavaScript in another user's browser.

Evidence: The search parameter is reflected into the HTML response without proper HTML encoding.

Recommendation: Apply context-aware output encoding and validate user input. Implement an appropriate Content Security Policy where possible.

FINDING 003: Missing Security Headers

Severity: Medium

Affected Endpoint: /

Description: Several recommended HTTP security headers are missing from the application responses.

Evidence: Missing: Content-Security-Policy; X-Content-Type-Options; Strict-Transport-Security.

Recommendation: Configure the web server or application framework to send appropriate security headers.

FINDING 004: Weak Password Policy

Severity: Medium

Affected Endpoint: /login

Description: The application allows users to create passwords that do not meet a sufficiently strong password policy.

Evidence: Passwords shorter than commonly recommended minimum lengths were accepted during testing.

Recommendation: Enforce a stronger password policy and encourage long, unique passwords. Consider rate limiting and multi-factor authentication.

FINDING 005: Information Disclosure

Severity: Low

Affected Endpoint: /api/status

Description: The API response exposes detailed server and software version information that could assist attackers during reconnaissance.

Evidence: The response includes the application framework name and version.

Recommendation: Remove unnecessary software version information from publicly accessible responses.

SUMMARY

Total Findings: 5

Critical: 1 **High:** 1 **Medium:** 2 **Low:** 1

Overall Risk: High

Risk Score: 82

END OF REPORT